



Lab 12 — Run an AI Incident Response Exercise

Topic 03: Governance Controls Across the AI Lifecycle

Objective: Apply lifecycle governance under pressure by running an AI security incident from detection through containment, assessment, notification and lessons learned.

Goal: A tabletop exercise tests whether your governance survives contact with reality. The trainer will run a prompt-injection incident against NovaAssist in timed injects. You will respond as the governance team, making the decisions your operating model says you own.

What you'll build: A completed incident record: timeline, containment decision, personal-data impact assessment, PDPA notification determination and five improvement actions.

Tools and data: Incident inject pack (incident-injects.md), incident record template, Lab 7 operating model

Data files in this lab

- data/incident-injects.md
- data/incident-record-template.md

Step-by-step

1. Take your role from the Lab 7 operating model. Every learner holds one role — governance lead, system owner, DPO, security lead or executive — and answers only for that role's decisions.
2. Receive inject 1: a customer reports that NovaAssist sent them a summary containing another customer's account details. Record the time and your first three actions.
3. Decide on containment. State who authorises disabling the agent, how long it takes, and whether you disable fully or restrict its outbound tools. Justify the choice against business impact.
4. Receive inject 2: the monitoring log shows 340 similar agent runs in the preceding six hours. Reassess the scope and record how your response changes.
5. Preserve evidence. List exactly what you must capture before anything is reset: prompts, tool-call logs, model version, agent configuration, approval records and the injected content itself.

6. Assess the personal-data impact: how many individuals, what data classes, and whether the incident meets the notification threshold under the PDPA. Record the reasoning, not just the conclusion.
7. Receive inject 3: a journalist calls asking about an AI data leak at the bank. Decide who responds and what may be said while the assessment is incomplete.
8. Determine the notification position: whether the PDPC and affected individuals must be notified, within what timeframe, and who signs off. Record the decision and its basis.
9. Identify the root cause using your Lab 3 analysis: the agent combined private data access, untrusted content and an outbound channel. State which control would have prevented it.
10. Write the five improvement actions with owners and dates, and record the one governance gap this exercise exposed in your own operating model.

Test it

Your incident record has a timestamped timeline, a containment decision with a named authoriser, a reasoned PDPA notification determination, and five improvement actions with owners. You can name the single control that would have prevented the incident.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.